

01/09/2026
י"ט אלול תשפ"ו

הקפדה על כללי הפיתוח המאובטח

באתרי Web

פעולות מידיות לביצוע:

- וודאו כי פיתוח האתר מתבצע על פי מתודולוגיות פיתוח מאובטח מוכרות.
- לימדו ויישמו את נושא הפיתוח המאובטח במערכות המפותחות עבור ארגונכם.

[תקציר]

- לאחרונה טיפל מערך הסייבר הלאומי באירוע בו אתר מסוים חשף מידע רגיש של משתמשים עקב שגיאות שונות במהלך הפיתוח וההפעלה של האתר.

[פרטים]



שיתוף מידע עם מערך הסייבר הלאומי אינו מחליף חובת דיווח לגוף מנחה כלשהו, ככל שחלה על הגוף חובה כזו.

המידע נמסר כפי שהוא (as is), השימוש בו הוא באחריות המשתמש ומומלץ להיעזר באיש מקצוע בעל הכשרה מתאימה לצורך הטמעתו.

- חשיפה של ספריית ה-git של האתר, והטמעת מפתחות API שונים באופן שהיו נגישים לתוקפים פוטנציאליים, אפשרו הגעה לנתונים רגישים של משתמשי האתר.

[דרכי התמודדות]

- וודאו כי האתר מפותח על פי מתודולוגיות פיתוח מאובטח מוכרות.
- וודאו כי כלים המשמשים לפיתוח האתר, כגון ספריית ה-git ומפתחות API שונים, אינם חשופים למשתמשים.
- היעזרו ברשימת המקורות המצורפת ללימוד על פיתוח מאובטח, והפגיעויות העיקריות הנובעות מאי-שימוש בכללי הפיתוח המאובטח המקובלים.

מקורות

1. https://www.gov.il/BlobFolder/guide/disciplinary_torah/he/tora070626.pdf
2. <https://owasp.org/www-project-top-ten/>
3. <https://owasp.org/www-project-web-security-testing-guide/>
4. <https://owasp.org/www-project-application-security-verification-standard/>
5. https://developer.mozilla.org/en-US/docs/Learn_web_development/Extensions/Server-side/First_steps/Website_security
6. <https://web.dev/>
7. <https://portswigger.net/web-security>